becker® MINING SYSTEMS

LASEC

Tarea del Módulo 3:

Parte 2 – Investigación en GHDB

Adolfo Mandujano Lara

Índice

Introducción.....2
Dork 1.....3
Dork 2.....4
Dork 3.....5

Introducción

La Google Hacking Database (GHDB) de Exploit Database es una base de datos que recopila Google Dorks, es decir, consultas avanzadas en Google Search diseñadas para encontrar información sensible que ha sido indexada públicamente en internet.

Estas búsquedas permiten identificar errores de configuración en servidores, archivos expuestos, credenciales, bases de datos o información interna de sitios web. Muchos de estos datos quedan accesibles porque los administradores de sistemas almacenan archivos en servidores web sin restringir el acceso o sin configurar correctamente la seguridad.

Para un especialista en seguridad informática, estudiar estos dorks es importante porque permite entender cómo los atacantes realizan reconocimiento pasivo, es decir, cómo recopilan información sin interactuar directamente con el sistema objetivo. Este proceso es una de las primeras etapas en auditorías de seguridad y pruebas de penetración.

En esta sección se analizarán tres dorks obtenidos de la Google Hacking Database, explicando qué tipo de información buscan, qué tipo de exposición pueden detectar y en qué categoría se clasifican dentro de GHDB. El objetivo es comprender cómo la información pública mal protegida puede representar un riesgo de seguridad para organizaciones y servicios en línea.

Dork 1

Google Dork

site:.com intitle:"index of" /payments.txt

¿Qué busca?

Busca directorios abiertos en sitios web (.com) que contienen un archivo llamado payments.txt. El término **"index of"** indica que el servidor permite ver públicamente la lista de archivos dentro de una carpeta.

¿Qué tipo de exposición detecta?

Este tipo de búsqueda puede revelar archivos internos relacionados con pagos o transacciones.

En el caso encontrado, el servidor mostraba una carpeta llamada:

/payments/

Dentro de la carpeta había varios archivos del sistema, por ejemplo:

```
Transaction.txt
config.class.php
db-data.php
params.php
payments-in.php
payments-validate.php
paymentsAPI.class.php
```

Uno de los archivos (Transaction.txt) contenía **registros de transacciones en formato JSON**, por ejemplo:

```
TransactionType: Pay Bill
TransID: OJ691HCWBV
TransAmount: 10.00
OrgAccountBalance: 57621.00
MSISDN: 254708374
```

Esto indica que el sistema estaba guardando **información de pagos y Nombres completos de los clientes en un archivo accesible públicamente**.

Categoría GHDB

Files Containing Juicy Info

Esta categoría agrupa dorks que buscan archivos con información sensible o valiosa.

Riesgo

Exposición pública de registros de transacciones, datos de clientes y archivos internos del sistema de pagos, lo que puede facilitar fraude, robo de información o ataques dirigidos al sistema.

Dork 2

Google Dork

intitle:"index of" "config.php.txt"

¿Qué busca?

Busca directorios abiertos en sitios web que contienen archivos llamados: ***config.php.txt***

Estos archivos suelen ser copias de archivos de configuración de aplicaciones hechas en PHP.

Muchas veces aparecen cuando un desarrollador renombra el archivo para revisarlo o hacer un respaldo y accidentalmente queda público.

¿Qué tipo de exposición detecta?

Este tipo de archivo puede contener **credenciales internas del sistema**.
En el caso encontrado, el archivo mostraba configuraciones de WordPress, incluyendo:

```
DB_NAME = wordpress_production
DB_USER = wp_user
DB_PASSWORD = WpConfigTxtPassword2024!Secret
DB_HOST = wpconfigtxt-db.internal
API_KEY = wp-config-txt-api-key
```

Esto revela información crítica como:

- nombre de la base de datos
- usuario de la base de datos
- contraseña de acceso
- servidor interno de base de datos
- claves de API del sistema

Categoría GHDB

Files Containing Juicy Info

Esta categoría agrupa dorks que buscan archivos con información sensible o valiosa expuesta públicamente.

Riesgo

Un atacante podría utilizar estas credenciales para intentar acceder a la base de datos del sitio web, lo que permitiría robar información de usuarios, modificar datos o comprometer completamente el sistema.

Dork 3

Google Dork

intitle:"index of" "/concrete/Password"

¿Qué busca?

Busca directorios abiertos en sitios web que contienen la carpeta: **/concrete/Password**

Esta estructura pertenece al CMS Concrete CMS, un sistema utilizado para crear y administrar sitios web.

Cuando aparece “index of”, significa que el servidor permite ver públicamente los archivos internos de esa carpeta.

¿Qué tipo de exposición detecta?

En los resultados encontrados se observan archivos PHP relacionados con el manejo de contraseñas del sistema, por ejemplo:

```
PasswordChangeEventH..> 2020-12-15 14:38 1.1K
PasswordUsageTracker..>  2020-12-15 14:38 3.3K
```

Estos archivos forman parte del sistema interno que controla cambios de contraseña y seguimiento de uso de credenciales dentro del sitio.

Esto revela información sobre cómo funciona el sistema de autenticación del sitio web.

¿Qué puede aprender un atacante?

Al ver estos archivos, un atacante puede:

- identificar qué CMS usa el sitio
- entender cómo se gestionan las contraseñas
- analizar el sistema de autenticación
- buscar vulnerabilidades específicas de ese CMS

Este proceso se conoce como **fingerprinting de la tecnología del servidor**.

Categoría GHDB

Sensitive Directories

Riesgo

Exposición de archivos internos del sistema de autenticación que permite identificar la tecnología del sitio y facilita la búsqueda de vulnerabilidades específicas del CMS.